Layer2Meetup@Tokyo Meeting Report

- BGIN is a multi-stakeholder discussion body / distributed think tank.

Regulatory Uncertainty for Lightning Businesses

bg in

blockchain
governance
initiative
network

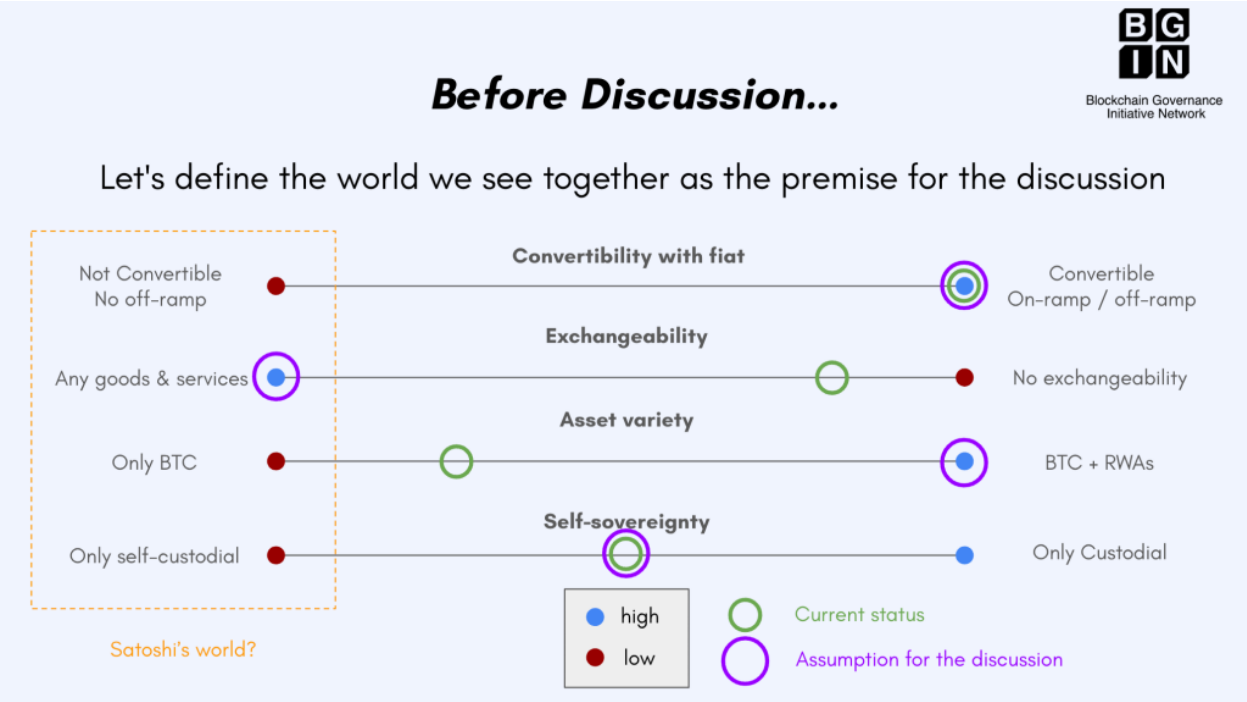
The Global Network for Blockchain Stakeholders™

© 2023 BGIN (Blockchain Governance Initiative Network) is registered as BN Association, a Japanese general association with its principal place of business at Shiba Building, 704, 4-7-6, Shiba, Minato-ku, Tokyo. All rights reserved.

The know-how described in this document was made available from contributions from various sources, including members of the BGIN and others. Although the BGIN has taken steps to help ensure that the know how is available for distribution, it takes no position regarding the validity or scope of any intellectual property or other rights that might be claimed to pertain to the implementation or use of the know how described in this document or the extent to which any license under such rights might or might not be available; neither does it represent that it has made any independent effort to identify any such rights. BGIN and the contributors to this document make no (and hereby expressly disclaim any) warranties (express, implied, or otherwise), including implied warranties of merchantability, non-infringement, fitness for a particular purpose, or title, related to this document, and the entire risk as to implementing this document is assumed by the implementer. The BGIN Intellectual Property Rights policy requires contributors to offer a patent promise not to assert certain patent claims against other contributors and against implementers. BGIN invites any interested party to bring to its attention any copyrights, patents, patent applications, or other proprietary rights that may cover technology that may be required to practice this document.

*This is a document co-created in the workshop session.

Assumption for the discussion



Wallets

- fake “self-custodial”

  Key questions

  - Is it a self-custodial wallet if you rely on third-party for running a lightning node?
  - What could the third party do if they run a lightning node for you?

  Discussion points

  - There’s a misconception that running a Lightning node for someone else can be done without full custody, but that’s not true. Companies might say they’re running the node for you while you maintain custody, but in reality, you’re trusting them with everything. They can create transactions that take all your funds, and you might unknowingly sign off on it. If you’re not running your own node, and you’re trusting a third party, you’re essentially giving them full control over your funds.

  - In Lightning, a third-party node operator can engage in several malicious activities. For instance, they can force-close channels or broadcast an outdated channel state to steal funds. Even though you might hold the private key to the Bitcoin network, the node operator still has a lot of control over the Lightning channels.

  - The problem is that in Lightning, it’s easy for a third party to trick you into signing something without fully understanding what it is. In theory, you should be able to sign

transactions yourself, but in practice, you're often signing blindly, which can lead to losing funds if the third party is malicious.

- Users need to know what to sign and if you're not running the node yourself you don't know what to sign. Users also need to remember which revocation key to reveal.
- Many companies think they can have self-custody while outsourcing running their lightning node to another company. So far this isn't really possible technically. There are projects like VLS which may help but right now aren't really designed for third party nodes.
- The solution is to make it easier for individuals to run their own Lightning nodes, rather than relying on third parties. If people could run nodes on their phones or personal devices, they would have more control over their funds, and it would reduce the risks associated with trusting third-party node operators. Buy it's much easier and more tractable on layer 1. On layer 1, if you have a custodial wallet, the risks are more manageable. When sending Bitcoin, you don't need any external information; you know your UTXO, you can sign and create transactions offline, and then give that transaction to the provider. Hardware wallets, for example, handle this well. In Lightning, it's more complex. There are still risks with third parties on layer 1, but they are smaller and more understood by the industry.

- Security

Key question

- LN-supported wallets are mostly hot wallets. Do we need new operational requirements for custodial service providers managing LN-supported hot wallets?

Discussion points

- The "need to always watch the transactions on LN" is pretty well mitigated by watchtowers, which don't have private keys and can only defend channels from invalid closures. The main reason to keep the node online and key material in memory is because nodes need to sign to receive funds.
- Unlike layer one, in Lightning, you need to sign to receive payments. There's no passive reception. If you're routing funds, you need to be constantly online. If you go offline, you won't be able to receive, but your channels can still be safe if you have a watchtower.
- You often have to have your Lightning node online, meaning the key material is stored in RAM or on the device. Work is being done to move the key material to something more secure, like an HSM or a USB device, but right now, the private key is often actively used.
- Most exchanges would prefer cold storage, but they have to keep some funds online to manage Lightning transactions. Exchanges that implement Lightning have to manage the balance between security and functionality, often keeping some funds in hot wallets for Lightning operations.

    - Some exchanges manage this by limiting the amount of money kept in Lightning nodes, replenishing from cold storage as needed. In the future, multi-signature solutions may help exchanges manage security better by splitting the keys across several servers, but this is still a few years away.

    - A person I spoke to in the Bitcoin community said that Japanese exchanges hesitate to support Lightning due to regulatory uncertainties. But exchanges are concerned about securing customer assets, which is an important discussion point for implementing Lightning in Japan.

- KYC/ AML・CFT

  Key questions

    - How can we combat money laundering and other malicious activities?
    - Is there any consideration of developing a solution to balance between them?
    - Any other measures being discussed in the Bitcoin community?

  Discussion points

    - In the Ethereum community, for example, Vitalik Buterin co-authored a paper that proposes using a mixing service to exclude bad actors while maintaining privacy, regardless of how effective and practical it is.

    - The Lightning Network protocol developers are going in the opposite direction, enhancing privacy and making it harder to trace transactions. For example, if a company wants to know the origin of an HTLC, it can't because the protocol uses onion routing, and tracing the origin is difficult. Efforts are underway to decouple Lightning Network channels from the layer1 UTXOs, making it harder to link transactions. This may frustrate blockchain analytics companies, but the community is focused on privacy.

    - While privacy is a priority, there isn't much interest in building solutions that help with AML/CFT measures. The focus is on making open-source software for individuals, and there’s little concern for financial companies or exchanges.

Routing (Intermediary) Node

- Customer Asset Segregation

  Key questions

    - Can routing node operators lose deposited customer assets or engage in malicious activities with customer assets?

  Discussion points

    - Lightning routing nodes follow the paths directed by the network and have atomicity, so transactions either fail or succeed without intermediaries seizing assets. Also, as long as the routing node has enough liquidity, the system should work fine.

    - If regulators tried to regulate these routing nodes, they'd probably just shut down. The Lightning protocol is designed so that routing nodes process payments without knowing

where they come from or where they go. It's better to focus on endpoints and custodial services for regulation rather than routing nodes, which function similarly to miners on the Bitcoin network.

- The connection to routing nodes is usually automatic, and you connect based on liquidity and connectivity, not individual trust. The routing nodes have multi-sigs with other nodes, but typically, the routing node isn't directly connected to the customer. The routing node simply passes payments along. When you hold a self-custodial wallet and use Lightning, you need to connect to routing nodes with large liquidity. But you only need to have a direct channel with the routing node, and that's automatic. You don't usually deal directly with the routing node.
- A routing node operated by a service provider has a multisig address with customers' nodes that have a direct channel with the routing node. But the service provider need their private key to move fund around, though the service provider can exit if the other is offline (which can be mitigated by watchtower)

- Limited transaction amount

  Key questions

  - Can the transaction amount be a reason not to be regualted?

  Discussion points

  - There are many bad activities possible with small transactions. And there are some technologies being developed to allow large transactions by splitting routing paths. Limited transaction amount itself could not be the reason not to be regulated.

- KYC and AML/CFT

  Key questions

  - Can KYC/AML・CFT measures be implemented in routing nodes?

  Discussion points

  - routing nodes can't link the sender and recipient because routing nodes can know only the nodes in front and behind and because the sender and recipient do not have their own multi-sigs when they do not have a direct channel.
  - Supposing that we can't make any changes to the privacy enhancing mechanisms of Lightning, routing nodes can see the persons in front and behind of the transaction path. If all intermediary nodes need to do KYC and due-diligence of the other party, we can link the sender and the recipient. But it costs too much and does not sound efficient.

- Decentralization

  Key questions

  - Can routing node owners engage in Intentional blocking if they are centralized?

Discussion points

- Technically possible by being offline for a long period. The routing node owner has bitcoin in multi-sigs with their customers. Customers can withdraw their assets after waiting for a certain period, when the routing node owner intentionally blocks transactions somehow.

- If there is too much dependence on a few routing nodes, transaction failure and delay could happen easily. There is also a privacy risk that transaction analysis becomes easier. But they are not “regulatory” risks.

Crypto Exchanges that support LN

- Wallet management

  Key questions

  - It is not that they are required to hold customer assets in cold wallets (in Japan yes), but supporting LN makes them hold customer assets in hot wallets. Is this a security risk?

  Discussion points

  - See page 5

- KYC and AML/CFT

  Key questions

  - Is the due-diligence of the counterparty feasible? Custodial service providers might need to store past transaction data as a sender and receiver, but what about as an operator of a routing node?

  Discussion points

  - Existing crypto exchanges are required to perform due diligence on their counterparties and customers. When it comes to supporting Lightning, the exchange could potentially store past transaction commitment data and conduct KYC with anyone who has a direct channel to its node. While this is technically feasible, it becomes operationally complex and may impose limitations for blockchain analysis.

  - Many exchanges think supporting Lightning is doable from a regulatory standpoint—it’s not very different from Layer 1. But the big issue is that supporting Lightning requires significant engineering resources, and for most exchanges, it’s not a huge moneymaker. While some of them might adopt Lightning due to customer demand, the complexity and cost may deter exchanges from pioneering this space.While regulation might seem like a barrier, it's more about the business case and engineering effort. It’s a lot of work for exchanges to implement Lightning nodes securely.

Watchtower

Key questions

- Are there any evil acts that watchtowers can work on arbitrarily, while there are some functions to prevent evil acts. Watchtowers just have encrypted commitment transaction data. Only when it detects an attempt to broadcast an outdated commitment transaction, they can submit just the appropriate penalty transaction.
- How are watchtowers incentivized to act correctly?
- Is watchtower decentralized? Is there any single point of failure?

Discussion points

- The potential for collusion is minimal. Watchtowers can only fail by going offline. The data given to them is encrypted commitment transaction data and doesn't mean anything on its own. Only when it detects an attempt to broadcast an outdated commitment transaction, they can submit just the appropriate penalty transaction. There's no real mechanism for watchtowers to act maliciously, except by not performing their duty.
- Incentives for watchtowers are not well-defined since the need to act rarely occurs, making it hard to implement a meaningful reward system. The cost of running a watchtower is low, and services might charge a small monthly fee, but the current setup seems to work without extensive incentive mechanisms.
- Using multiple watchtowers to protect the same channel is allowed, so any individual tower is a single point of failure, but they can be redundant. Even if several try to act simultaneously, it doesn't break the system.